

CO2-AT2

OSINT Reconnaissance, Phishing Simulation & Aggressive Nmap Scanning

Note: This report follows a standard reconnaissance/pentest lab methodology. Illustrative/placeholder data (marked as example) is used in place of any real scraped personal data, since live tool execution against external targets and real employee inboxes was not performed in this environment. Replace the example rows with your own theHarvester/GoPhish/Nmap output when running this in your Kali lab.

Question 1: OSINT Email Enumeration on tesla.com using theHarvester — 20 Marks

1. Objective

To perform passive OSINT reconnaissance against the domain tesla.com using theHarvester in Kali Linux, enumerate publicly available email addresses, subdomains, hosts, and IP addresses, categorize the discovered emails by likely organizational role, and analyze how this information could support an attacker's reconnaissance and social-engineering phase.

2. Tool and Commands Executed

```
theHarvester -d tesla.com -b all -l 500
```

```
theHarvester -d tesla.com -b google,bing,linkedin -l 300 -f tesla_report.html
```

Key flags: -d (target domain), -b (data source/search engine — 'all' queries every supported source), -l (result limit per source), -f (save results as an HTML/XML report for evidence).

3. Sample Findings Format (screenshots + output)

A completed report should include: (a) a terminal screenshot of the command being run, (b) the summary output block listing counts of emails/hosts/IPs found, and (c) the generated HTML report opened in a browser. Example structure of the results table to include in your submission:

Category	Example Finding	Source
Emails found	e.g., firstname.lastname@tesla.com (pattern identified)	Google, Bing, LinkedIn
Subdomains	e.g., shop.tesla.com, ir.tesla.com, developer.tesla.com	Search engines, crt.sh
Hosts / IPs	e.g., IP ranges resolved for discovered subdomains	DNS resolution
Employee names	e.g., names tied to LinkedIn/job-title OSINT	LinkedIn, Google

4. Categorizing Discovered Emails by Likely Role

Harvested addresses are typically grouped by naming convention or by the context (webpage/job listing) they were found in:

Category	Typical Pattern / Indicator	Attacker Value
Support	support@, help@, customerservice@	Useful for impersonating IT/customer support in phishing
Sales	sales@, info@, contact@	Lower-privilege target, good for initial foothold/pretexting
Human Resources	hr@, careers@, recruiting@	High-value for CV-malware attacks and payroll/BEC fraud
Administration	admin@, office@, finance@	High-value for invoice fraud and privileged access attempts
Technical Teams	firstname.lastname@ tied to IT/dev job titles on LinkedIn	High-value for credential harvesting and targeted spear-phishing on privileged systems

5. How This Information Aids an Attacker's Reconnaissance

- Confirms the organization's email naming convention (e.g., first.last@domain), allowing an attacker to programmatically guess valid addresses for employees not directly found.
- Subdomains and hosts reveal the external attack surface (portals, dev/staging environments, VPN endpoints) that may be less hardened than primary infrastructure.
- Role-based categorization lets an attacker prioritize targets: HR/Finance for business email compromise, Technical/IT for credential and infrastructure access.
- Combined with LinkedIn/job-title OSINT, attackers build detailed target profiles for pretexting (impersonating a vendor, recruiter, or executive).

6. Use in Spear-Phishing, Credential Harvesting, and Impersonation

- Spear-phishing: Crafting highly personalized emails referencing the target's real name, role, and department to increase click-through and trust.
- Credential harvesting: Sending Technical/Admin staff a fake SSO/VPN login page cloned to match internal branding discovered during OSINT.
- Impersonation/BEC: Spoofing an executive or HR email (using a lookalike domain) to request wire transfers, W-2 data, or gift-card purchases from Finance staff.
- Attachment-based attacks: Sending HR a fake 'resume' or Support a fake 'customer complaint' laced with malware, since these roles routinely open external attachments.

7. Recommended Countermeasures

- Minimize publicly listed personal emails; use role-based aliases (e.g., support@, hr@) instead of exposing individual employee addresses where possible.
- Enforce SPF, DKIM, and DMARC (with a reject/quarantine policy) to prevent domain spoofing and lookalike-domain impersonation.
- Conduct regular employee security-awareness training focused on recognizing spear-phishing and BEC attempts.
- Restrict what employees publish on LinkedIn/social media regarding internal tools, org charts, and job responsibilities.
- Deploy email filtering/anti-phishing gateways with attachment sandboxing and external-sender banners.
- Enforce multi-factor authentication (MFA) on all corporate accounts so harvested/guessed credentials alone cannot grant access.
- Periodically run self-OSINT assessments (theHarvester, crt.sh, Shodan) to discover and remediate information leakage before attackers do.

8. Risk Analysis Summary

The ease of enumerating a valid naming convention, active subdomains, and role-mapped contacts represents a Medium-to-High reconnaissance risk. While no exploitation occurs at this stage, the gathered intelligence significantly increases the success probability of downstream spear-phishing, BEC, and credential-harvesting attacks, making OSINT hygiene an important preventive control.

Question 2: GoPhish Phishing Awareness Simulation — 20 Marks

1. Objective

To design and run a controlled phishing awareness simulation using GoPhish against dummy employee accounts in the lab environment, then measure and report on delivery, open, and click metrics to guide awareness improvements.

2. Simulation Setup Steps

- Configure GoPhish admin console and verify the Sending Profile (SMTP relay) used to dispatch simulated emails to the lab mail server.
- Create a Landing Page that mimics a realistic internal login portal (for credential-capture measurement) without storing real credentials in production use.
- Create an Email Template — e.g., an 'IT Password Reset Required' or 'HR Policy Update' themed message with a tracked link/button.
- Import the dummy employee Target Group (names + lab email addresses) provided for the exercise.
- Launch the Campaign, linking the sending profile, landing page, template, and target group, with a defined launch and end date.
- Monitor the live Campaign Results dashboard as events (sent, opened, clicked, submitted data) are recorded in real time.

3. Sample Campaign Report

Metric	Result	Interpretation
Emails Sent (Delivery Rate)	100% delivered to dummy accounts	Sending profile and DNS/SMTP configuration functioned correctly
Open Rate	e.g., 65% opened the email	Majority of recipients trusted the sender/subject enough to open it
Click Rate	e.g., 38% clicked the tracked link	Over a third proceeded past the subject line to the landing page
Data Submitted	e.g., 15% submitted credentials on landing page	A meaningful subset would have exposed real credentials in a live attack

Your submitted report should include GoPhish dashboard screenshots (Overview chart, Timeline of events, and the Results table per recipient) as evidence alongside these figures.

4. Recommendations to Improve User Awareness

- Conduct recurring simulated phishing campaigns (at least quarterly) to build sustained vigilance rather than one-off training.
- Deliver immediate, targeted micro-training to any employee who clicks or submits data, explaining exactly which red flags were present.
- Introduce a one-click 'Report Phishing' plugin so employees can flag suspicious emails directly to the security team.
- Track metrics over successive campaigns (click-rate trend, report-rate trend) to demonstrate measurable improvement to leadership.
- Combine simulations with instructor-led or e-learning modules covering URL inspection, sender verification, and safe attachment handling.
- Enforce technical backstops (MFA, email filtering, SPF/DKIM/DMARC) so a single human error does not translate directly into a breach.

Question 3: Nmap Aggressive Scan (-A) on scanme.nmap.org — 10 Marks

1. Objective

scanme.nmap.org is a host explicitly published by the Nmap project for lawful scanning practice. This exercise uses the Aggressive scan option to gather OS fingerprinting, open ports, service versions, and traceroute data, then evaluates how that intelligence could be leveraged for a social-engineering attack against the target organization's IT support team.

2. Command Executed

```
nmap -A -T4 scanme.nmap.org
```

The -A flag enables OS detection (-O), version detection (-sV), script scanning (-sC), and traceroute in a single scan; -T4 speeds up scan timing for a responsive lab exercise.

3. Typical Findings

Category	Typical Result
Open Ports	22/tcp (SSH), 80/tcp (HTTP) commonly reported open on this test host
OS Detection	Linux-based OS fingerprint (kernel/version guess with confidence %)
Service Versions	OpenSSH version banner; web server (e.g., Apache) banner and version
Traceroute	Hop-by-hop path from the scanning machine to the target

Exact banner versions and hop counts vary run-to-run and should be captured via a live screenshot of your own scan output for the submitted report.

4. Leveraging Findings for Social Engineering Against IT Support

- Pretext creation: Knowing the exact OS and SSH/web server version lets an attacker call or email IT support posing as a 'vendor' reporting a fake vulnerability in that specific software version, prompting a support technician to install a malicious 'patch' or grant remote access.
- Credibility building: Referencing accurate technical details (exact service version, hostname, open ports) in a phone/email pretext makes the attacker sound like a legitimate engineer or auditor, lowering the support team's suspicion.
- Helpdesk impersonation: Attacker cites the discovered service info while requesting a password reset or MFA bypass 'to fix the reported issue,' exploiting the support team's instinct to be helpful.
- Targeted follow-up phishing: The scan output guides a tailored phishing email (e.g., a fake OpenSSH security advisory) sent specifically to IT staff likely to manage that service.

5. Defensive Recommendations

- Minimize exposed service banners (disable or obscure version strings) so scan output yields less exploitable detail.
- Train IT support staff to verify caller/sender identity through an independent channel before acting on any 'vulnerability report' or access request.
- Implement a formal change-management process requiring ticket verification before installing patches or granting remote access.
- Apply the principle of least privilege and MFA for all support/administrative accounts to limit damage from a successful social-engineering attempt.
- Regularly self-scan public-facing hosts and close or firewall unnecessary ports/services to reduce the attacker's available pretext material.